

Manual 41 — UK GDPR / Data Protection Act Controlled Implementation

****Controlled baseline:**** UK GDPR and Data Protection Act 2018 as amended by the Data (Use and Access) Act 2025, subject to release-time legislative reversion.

****Boundary:**** statutory text, PECR where applicable, ICO statutory codes/guidance, sector duties, contracts, and organization-specific practices remain distinct source layers.

****Release rule:**** reversion current legislation and ICO implementation material at candidate freeze.

Chapter 01 — Purpose, scope, and source hierarchy

Define the controlled legal/source hierarchy, applicability method, ownership, change watch, and evidence index. Do not present regulator guidance as statutory wording.

Chapter 02 — Applicability and territorial scope

Determine whether processing falls within UK data-protection law, including establishment, targeting, monitoring, exemptions, and cross-border operating facts. Record inclusion and exclusion rationale.

Chapter 03 — Controller, processor, and joint-controller roles

Assign roles by actual purposes, means, instructions, and relationships. Maintain role assessments, contracts, joint arrangements, and reassessment triggers.

Chapter 04 — Accountability and governance

Assign executive, DPO/privacy, legal, security, records, procurement, product, HR, and operational responsibilities. Maintain approvals, policies, decisions, risks, issues, and management-review evidence.

Chapter 05 — Records of processing and data inventory

Maintain processing records, systems, purposes, categories, data subjects, recipients, transfers, retention, lawful bases, security measures, and owners with traceable change control.

Chapter 06 — Lawful bases

Require a documented lawful-basis decision before processing. Separate contract, legal obligation, vital interests, public task, legitimate interests, consent, and other applicable statutory conditions.

Chapter 07 — Legitimate interests and recognized legitimate interests

Where relevant, document the applicable route, purpose, necessity, balancing or statutory conditions, safeguards, transparency, objection handling, and review triggers. Do not merge distinct legal routes.

Chapter 08 — Consent governance

Where consent is relied upon, ensure it is valid for the processing context and maintain capture, granularity, evidence, withdrawal, refresh, and downstream suppression controls.

Chapter 09 — Transparency and privacy information

Provide accurate, accessible privacy information reflecting actual processing, purposes, bases, recipients, transfers, retention, rights, complaint routes, and significant automated processing where applicable.

Chapter 10 — Purpose limitation and data minimization

Collect and use personal data for documented purposes and restrict data to what is appropriate for those purposes. Govern secondary use, compatibility analysis, and exceptions.

Chapter 11 — Accuracy and data quality

Define data-quality controls, correction paths, source reliability, propagation of corrections, and monitoring proportionate to processing risk and decision impact.

Chapter 12 — Retention, deletion, and archival

Maintain retention rules based on applicable legal, regulatory, contractual, records, litigation, and operational requirements. Implement defensible deletion and controlled exceptions.

Chapter 13 — Security of processing

Implement risk-appropriate administrative, technical, and organizational measures covering identity, access, encryption, resilience, logging, vulnerability management, recovery, and assurance.

Chapter 14 — Processor and contract governance

Select processors through due diligence and maintain required contractual instructions, confidentiality, security, subprocessor, assistance, deletion/return, audit, and incident obligations.

Chapter 15 — International transfers

Identify restricted transfers and document the lawful transfer mechanism, assessment, safeguards, supplementary measures, exceptions, onward-transfer controls, and monitoring as applicable.

Chapter 16 — Subject access requests

Operate controlled intake, identity/authority verification, search, exemption review, third-party balancing, response, secure delivery, timing, escalation, and evidence retention.

Chapter 17 — Rectification, erasure, and restriction

Define workflows for applicable correction, deletion, and restriction rights, including recipient notification, exceptions, legal holds, technical execution, and closure evidence.

Chapter 18 — Objection rights

Assess objections according to processing basis and context, including direct marketing and other applicable routes. Maintain decisions, suppression, escalation, and downstream implementation evidence.

Chapter 19 — Data portability

Determine when portability applies and provide applicable data in an appropriate structured format using secure transfer and identity controls. Document exclusions and delivery evidence.

Chapter 20 — Automated decision-making and profiling

Identify solely automated or materially significant decision processes, determine applicable legal conditions and safeguards, and maintain transparency, human-intervention, challenge, testing, and monitoring evidence.

Chapter 21 — Children and persons requiring special handling

Apply age-, capacity-, vulnerability-, service-, and context-appropriate transparency, design, consent/authority, risk, and safeguarding controls without assuming one universal threshold for all processing.

Chapter 22 — Special-category and criminal-offence data

Document applicable Article 9 conditions, DPA Schedule conditions, policy-document requirements where relevant, access restrictions, minimization, retention, and heightened assurance.

Chapter 23 — DPIAs and high-risk processing

Screen for high risk before launch or material change. Maintain DPIA scope, necessity/proportionality, risks, measures, residual risk, consultation/escalation, approval, and review triggers.

Chapter 24 — Personal-data breach response

Integrate detection, containment, evidence preservation, risk assessment, notification decisions, communications, processor coordination, remediation, and breach-record obligations into incident response.

Chapter 25 — Complaints and regulator engagement

Maintain complaint intake, investigation, response, escalation, corrective action, regulator correspondence, legal review, and evidence preservation with clear accountability.

Chapter 26 — PECR and electronic communications boundary

Assess cookies, tracking, direct marketing, communications, and related PECR obligations separately from UK GDPR. Maintain consent/exemption logic, configuration evidence, suppression, and change watch.

Chapter 27 — Research, statistics, and public-interest overlays

Where applicable, document statutory bases, safeguards, purpose compatibility, minimization, access controls, transparency, exemptions, governance, and disclosure limitations for research/statistical processing.

Chapter 28 — Training and role competence

Deliver role-based privacy training for data handlers, rights teams, engineering, marketing, HR, procurement, security, executives, and incident personnel. Maintain completion and competency evidence.

Chapter 29 — Assurance and audit

Test notices, lawful bases, rights handling, contracts, transfers, DPIAs, security, breaches, retention, and automated processing using risk-based samples. Track findings through verified closure.

Chapter 30 — Metrics and management review

Track rights timeliness, complaints, breaches, DPIA backlog, transfer reviews, processor findings, retention exceptions, training, remediation aging, and legal change. Record management decisions and resources.

Chapter 31 — Localization, provenance, and release evidence

Freeze controlled EN/es-419/pt-BR candidates before final review; bind DOCX/PDF identities to SHA-256 and preserve source-version, structure, parity, accessibility, render, workflow-security, and staging evidence.

Chapter 32 — Implementation roadmap and release-time reverification

Implement through applicability/inventory; governance/bases; transparency/rights; processors/transfers; security/breaches; high-risk/automated processing; assurance and improvement. Immediately before publication, reverify current UK GDPR, DPA 2018, DUAA 2025 implementation state, PECR where claimed, and applicable ICO material. Publication remains sequential after Manual 40.